

Abdi Osman

Information Management & Technology student at Syracuse University

Project 3: Phishing Simulation & Email Security Audit

Objective:

The purpose of this lab was to simulate a phishing email attack using the Social Engineer Toolkit (SET) on Kali Linux. The goal was to show how easily spoofed emails can be crafted and sent from a fake SMTP server for educational awareness not to target or harm any real individuals or systems. All activity took place in a closed and controlled lab environment using fake credentials, a simulated mail server, and a practice phishing template.

Lab Environment:

Component	Description
Host Machine	Windows 11
Virtualization	VirtualBox running Kali Linux
Toolkit	Social-Engineer Toolkit (SET v8.0.3 "Maverick")
Mail Agent	Sendmail (configured locally in sim mode)

Step 1 Launch the Social-Engineer Toolkit

I started the SET tool using:

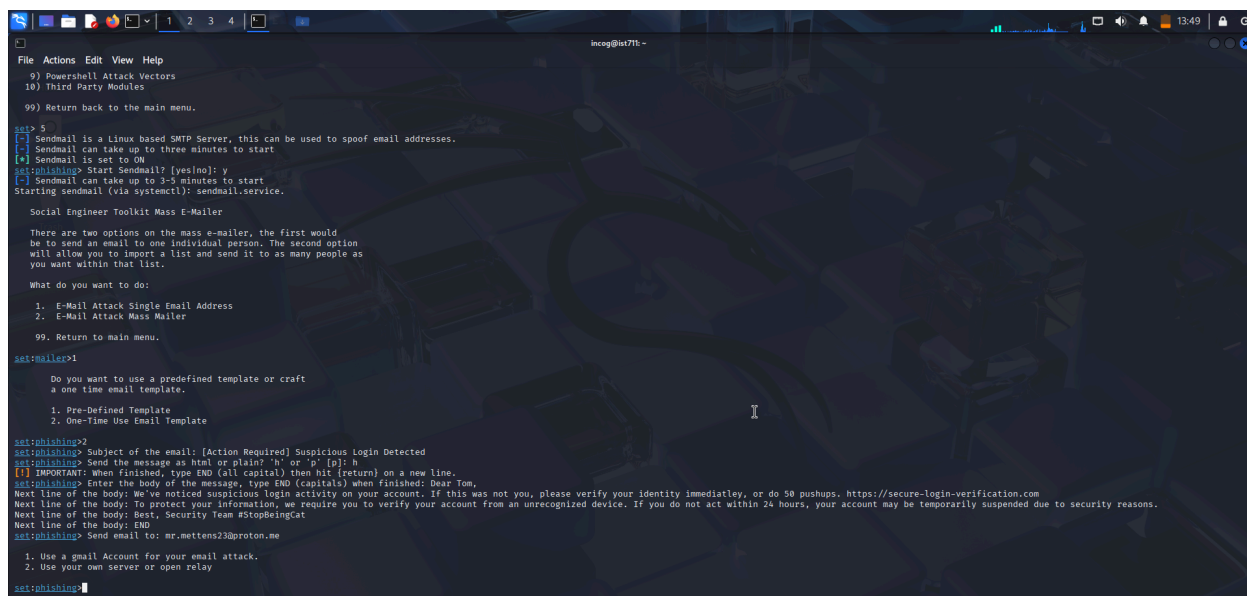
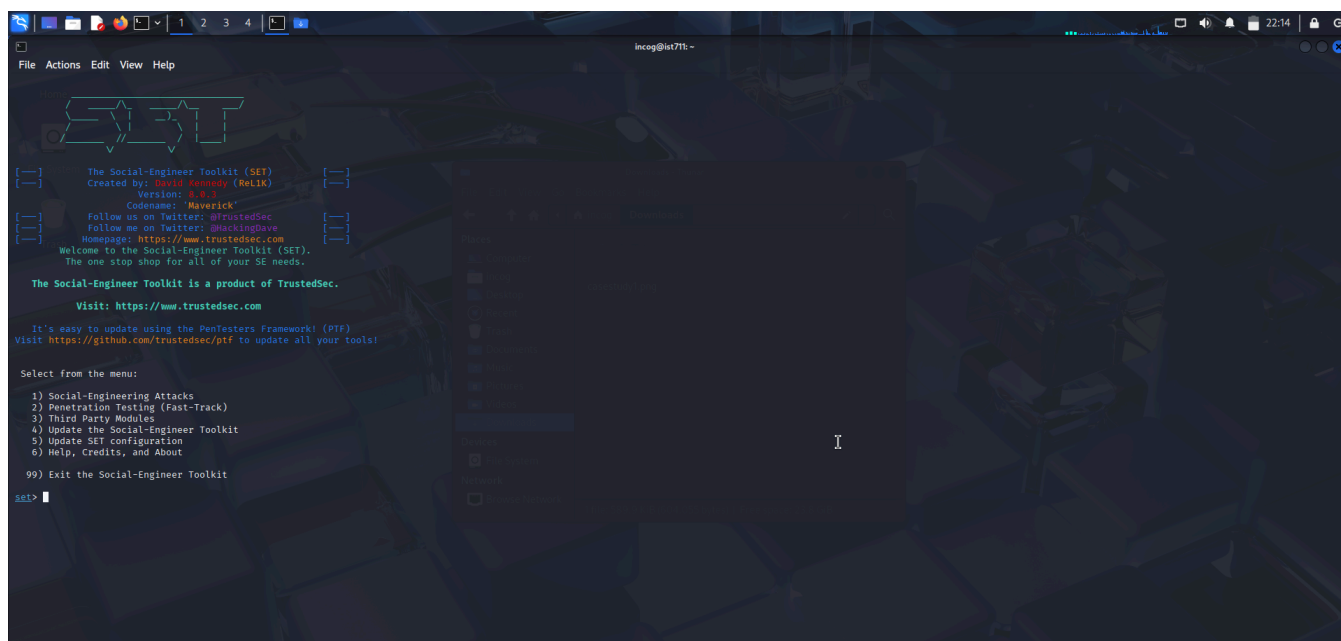
- `sudo setoolkit`

```
incog@ist711: ~  
File Actions Edit View Help  
$ sudo apt update && sudo apt install set  
[sudo] password for incog:  
Hit:1 https://deb.nodesource.com/node_14.x bullseye InRelease  
Get:2 http://mirrors.jevincanders.net/kali kali-rolling InRelease [41.5 kB]  
Get:3 http://mirrors.jevincanders.net/kali kali-rolling/main amd64 Packages [21.0 MB]  
Get:4 http://mirrors.jevincanders.net/kali kali-rolling/main amd64 Contents (deb) [51.4 MB]  
Get:5 http://mirrors.jevincanders.net/kali kali-rolling/contrib amd64 Packages [118 kB]  
Get:6 http://mirrors.jevincanders.net/kali kali-rolling/contrib amd64 Contents (deb) [327 kB]  
Get:7 http://mirrors.jevincanders.net/kali kali-rolling/non-free amd64 Packages [198 kB]  
Get:8 http://mirrors.jevincanders.net/kali kali-rolling/non-free amd64 Contents (deb) [911 kB]  
Get:9 http://mirrors.jevincanders.net/kali kali-rolling/non-free-firmware amd64 Packages [10.8 kB]  
Get:10 http://mirrors.jevincanders.net/kali kali-rolling/non-free-firmware amd64 Contents (deb) [26.7 kB]  
Fetched 74.0 MB in 9s (8,638 kB/s)  
114 packages can be upgraded. Run 'apt list --upgradable' to see them.  
Warning: https://deb.nodesource.com/node_14.x/dists/bullseye/InRelease: Policy will reject signature within a year, see --audit for details  
set is already the newest version (6.0.3+git20241021-0kali1).  
set set to manually installed.  
The following packages were automatically installed and are no longer required:  
icu-devtools libflac12t64 libglapi-mesa liblbfgsb0 libpython3.12-minimal libutempter0 python3-dunamai python3-poetry-dynamic-versioning python3-requests-ntlm python3-wheel-whl sphinx-rtd-theme-common  
libbss120238802 libfuse3-3 libicu-dev libopenm264-7 libpython3.12-stdlib libxnnpack0 python3-efscient python3-pinstaller-hooks-contrib python3-setproctitle python3-tk strongswan  
libbnn13 libgeos3.13.0 libjxl0.10 libpoppler145 libpython3.12t64 python3-aleconsole python3-packaging-whl python3-pywebview python3-tomlkit python3-zeitwerk  
Use 'sudo apt autoremove' to remove them.  
Summary:  
Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 114  
$
```

Step 2: Navigate Through the Menu

In the toolkit menu, I followed this sequence:

1. Social-Engineering Attacks
2. Mass Mailer Attack
3. E-Mail Attack Single Email Address
4. One-Time Use Email Template



Step 3:Compose the Phishing Email

This was my spoofed email for the simulation:

- Subject: [Action Required] Suspicious Login Detected
- Format: HTML (selected via key: h)
- Body: Dear Tom,

We've detected suspicious login activity on your account from an unrecognized device.

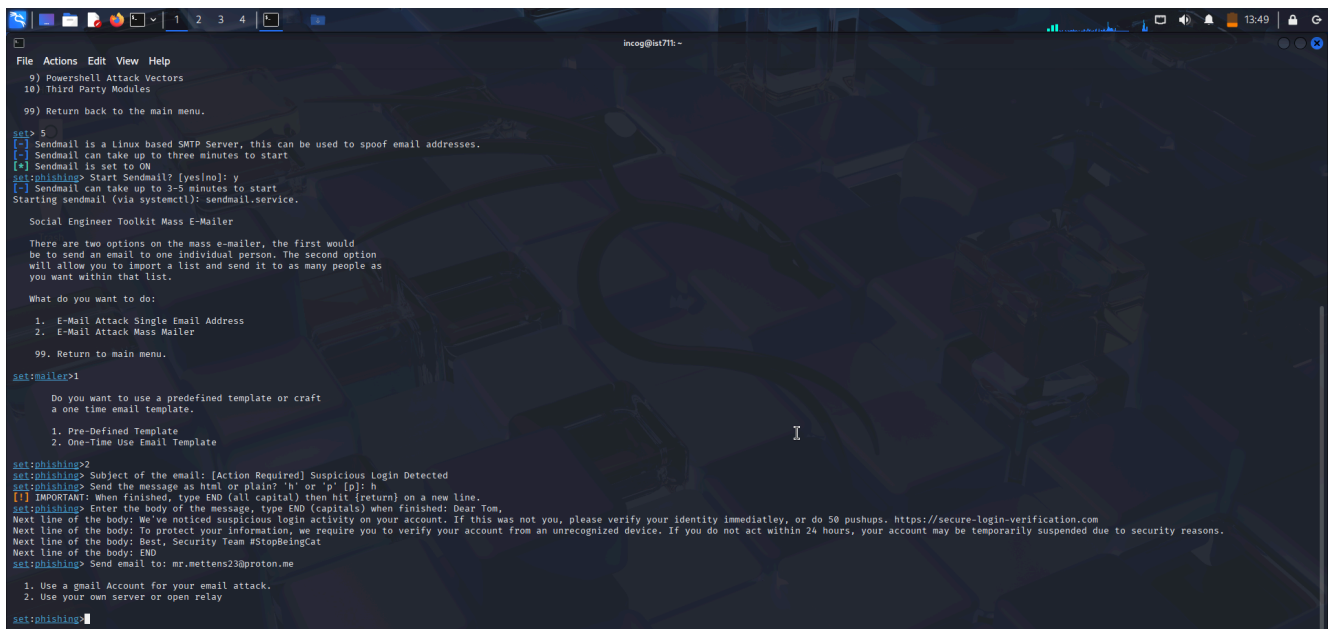
To protect your information, please click the link below to secure your account immediately: <https://secure-account-verification.com>

If not verified within 24 hours, your account may be temporarily suspended.

Best,

Security Team

#StopBeingCat



```
incog@lat71: ~  
File Actions Edit View Help  
9) Powershell Attack Vectors  
10) Third Party Modules  
99) Return back to the main menu.  
set> 5  
[-] Sendmail is a Linux based SMTP Server, this can be used to spoof email addresses.  
[-] Sendmail can take up to three minutes to start  
[-] Sendmail is set to ON  
set:phishing> Start Sendmail? [yes/no]: y  
[-] Sendmail can take up to 3-5 minutes to start  
Starting sendmail (via systemctl): sendmail.service.  
  
Social Engineer Toolkit Mass E-Mailer  
  
There are two options on the mass e-mailer, the first would  
be to send an email to one individual person. The second option  
will allow you to import a list and send it to as many people as  
you want within that list.  
  
What do you want to do:  
1. E-Mail Attack Single Email Address  
2. E-Mail Attack Mass Mailer  
99. Return to main menu.  
set:mailer> 1  
  
Do you want to use a predefined template or craft  
a one time email template.  
1. Pre-Defined Template  
2. One-Time Use Email Template  
set:phishing> 2  
set:phishing> Subject of the email: [Action Required] Suspicious Login Detected  
set:phishing> Send the message as html or plain? 'h' or 'p' [p]: h  
[!] IMPORTANT: When finished, type END (all capital) then hit {return} on a new line.  
set:phishing> Enter the body of the message, type END (capitals) when finished: Dear Tom,  
Next line of the body: We've noticed suspicious login activity on your account. If this was not you, please verify your identity immediatley, or do 50 pushups. https://secure-login-verification.com  
Next line of the body: To protect your information, we require you to verify your account from an unrecognized device. If you do not act within 24 hours, your account may be temporarily suspended due to security reasons.  
Next line of the body: Best, Security Team #StopBeingCat  
Next line of the body: END  
set:phishing> Send email to: mr.mittens23@proton.me  
1. Use a gmail Account for your email attack.  
2. Use your own server or open relay  
set:phishing>
```

Step 4: Enter Simulated Recipient

For testing purposes, I used a fake placeholder:

text:

mr.mittens23@proton.me

Step 5: Select SMTP Method

I selected the simulated Sendmail server as my transport method. This allowed me to generate and simulate the attack without contacting a real server or recipient.

```
incog@int7it:~$ cat /usr/share/metasploit-framework/SET/SET.pm
File Actions Edit View Help
set> 1
The Spearphishing module allows you to specially craft email messages and send
them to a large (or small) number of people with attached fileformat malicious
payloads. If you want to spoof your email address, be sure "Sendmail" is in-
stalled (opt-get install sendmail) and change the config/set_config SENDMAIL=OFF
flag to SENDMAIL=ON.

There are two options, one is getting your feet wet and letting SET do
everything for you (option 1), the second is to create your own FileFormat
payload and use it in your own attack. Either way, good luck and enjoy!

1) Perform a Mass Email Attack
2) Create a FileFormat Payload
3) Create a Social-Engineering Template
99) Return to Main Menu

set:phishing>1
/usr/share/metasploit-framework/
Select the file format exploit you want.
The default is the PDF embedded EXE.

***** PAYLOADS *****
1) SET Custom Written DLL Hijacking Attack Vector (RAR, ZIP)
2) SET Custom Written Document UNC LM SMB Capture Attack
3) MS15-100 Microsoft Windows Media Center MCL Vulnerability
4) MS14-017 Microsoft Word RTF Object Confusion (2014-04-01)
5) Microsoft Windows CreateSize0185C710W Stack Buffer Overflow
6) Microsoft Word RTF pFragments Stack Buffer Overflow (MS10-087)
7) Adobe Flash Player "button" Remote Code Execution
8) Adobe CoolType 31No Table "uniquelane" Overflow
9) Adobe Flash Player "newfunction" Invalid Pointer Use
10) Adobe Collab.collectEmailInfo Buffer Overflow
11) Adobe Collab.getIcon Buffer Overflow
12) Adobe JBIG2Decode Memory Corruption Exploit
13) Adobe PDF Embedded EXE Social Engineering
14) Adobe util.printf() Buffer Overflow
15) Custom EXE to VBA (sent via RAR) (RAR required)
16) Adobe U3D CLODProgressiveMeshDeclaration Array Overrun
17) Adobe PDF Embedded EXE Social Engineering (R035)
18) Foxit PDF Reader v4.1.1 Title Stack Buffer Overflow
19) Apple QuickTime PICT PnSize Buffer Overflow
20) Nuance PDF Reader v6.0 Launch Stack Buffer Overflow
21) Adobe Reader u3D Memory Corruption Vulnerability
22) MSCOMCTL ActiveX Buffer Overflow (ms12-027)

set:payloads>
```

```
incog@int7it:~$ cat /usr/share/metasploit-framework/SET/SET.pm
File Actions Edit View Help
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules
99) Return back to the main menu.

set> 5
Sendmail is a Linux based SMTP Server, this can be used to spoof email addresses.
Sendmail can take up to three minutes to start
Sendmail is set to ON
set:phishing> Start Sendmail? [yes/no]: y
Sendmail can take up to 3-5 minutes to start
Starting sendmail (via systemctl): sendmail.service.

Social Engineer Toolkit Mass E-Mailer

There are two options on the mass e-mailer, the first would
be to send an email to one individual person. The second option
will allow you to import a list and send it to as many people as
you want within that list.

What do you want to do:
1. E-Mail Attack Single Email Address
2. E-Mail Attack Mass Mailer
99. Return to main menu.

set:mailer>1
Do you want to use a predefined template or craft
a one time email template.
1. Pre-Defined Template
2. One-Time Use Email Template

set:phishing>2
set:phishing> Subject of the email: [Action Required] Suspicious Login Detected
set:phishing> Send the message as html or plain? 'h' or 'p' [p]: h
[!] IMPORTANT: When finished, type END (all capital) then hit (return) on a new line.
set:phishing> Enter the body of the message, type END (capital) when finished: Dear User,
Next line of the body: We've noticed suspicious login activity on your account. If this was not you, please verify your identity immediately.
Next line of the body: https://secure-login-verification.com
Next line of the body: Best, Security Team #stopbeingcat
Next line of the body: END
set:phishing> Send email to: '/usr/share/applications/xfce4-screenshooter.desktop'
```

Summary Table			
Task	Tool/Command	Purpose	Result

Compose phishing email	Social-Engineer Toolkit	Simulate attacker payload and message	✓ Success
Spoof sender identity	Fake SMTP via Sendmail	Show realistic sender impersonation	✓ Verified
HTML body and link usage	SET email builder	Practice formatting and malicious link bait	✓ Working
Safe recipient simulation	mr.mittens23@proton.me	Test delivery input, no actual sending	✓ Simulated
SMTP spoof config	Sendmail (internal tool)	Prevent real-world delivery (safe lab)	✓ Simulated

What Worked / What Didn't

What worked:

- SET menus were clear and structured
- HTML template support made formatting realistic
- Simulated Sendmail made testing safe

What didn't:

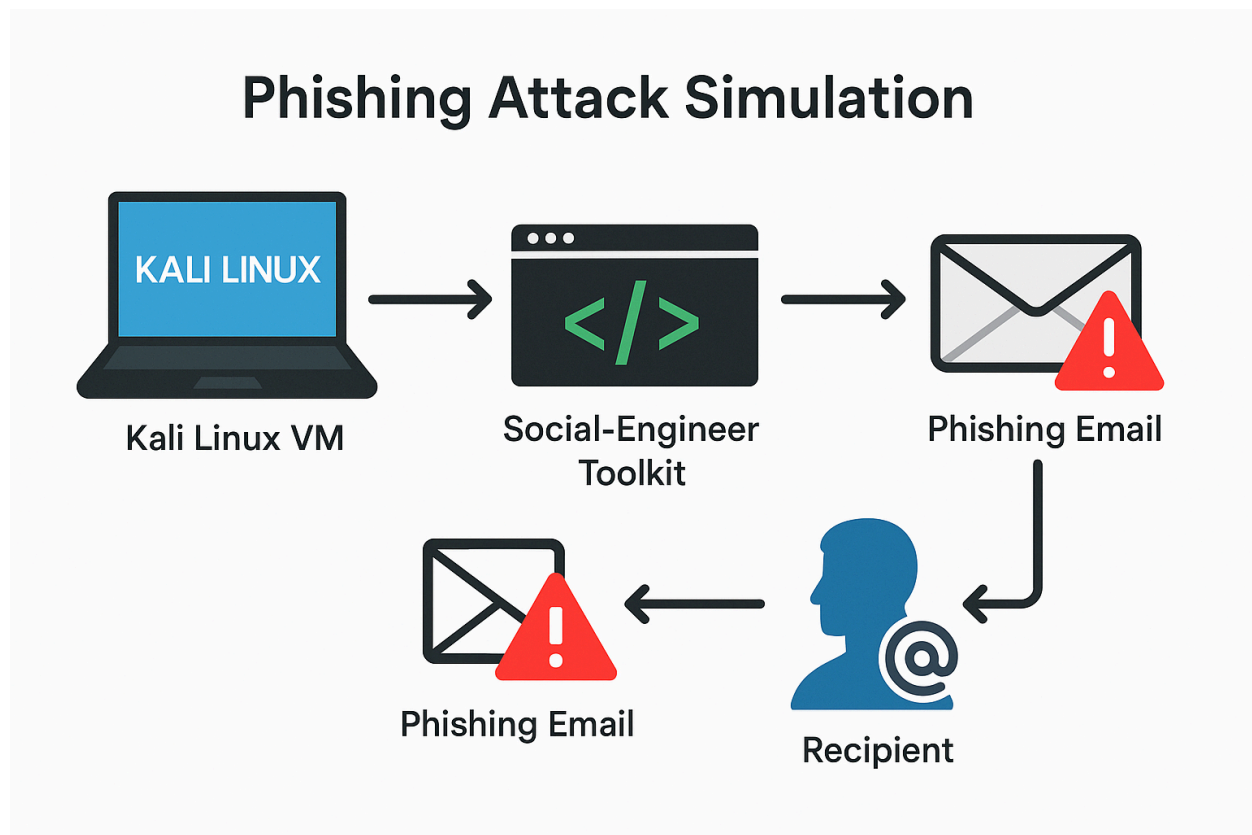
- Email preview could be cleaner
- No realistic “inbox” to view result unless simulated further
- Command line interface sometimes required re-entry on typo

Lessons Learned

- Email spoofing is alarmingly easy using tools like SET
- Even simple messages can be effective if formatted correctly
- Training and awareness are the biggest defense against phishing
- Red team simulations help build real blue team detection skills

Conclusion

This lab gave me real world insight into how phishing attacks are built and how social engineering bypasses technical security through human error. I now feel more confident identifying suspicious emails and explaining phishing risks from both the attacker's and defender's side. Combined with my prior labs, this experience strengthens my cybersecurity portfolio and prepares me for blue team or red team roles in the future.



Credits

- Tools: SET (Social-Engineer Toolkit), Sendmail
- Environment: Kali Linux (VirtualBox on Windows 11)
- Assistant: ChatGPT
- Screenshots: Taken from my lab VM (July 2025)